Executive Summary

LOAN-NEXTGEN is a state of the art, Android-based micro-lending platform engineered specifically for Uganda's low-to-middle income earners. Unlike traditional lending platforms, LOAN-NEXTGEN uses **mobile phones as digital collateral** while implementing **behavioral telecom scoring** that integrates deeply with Uganda's regulatory infrastructure (NIRA, UCC, CRB) and leveraging the use of predominant telecom companies.

The system eliminates agent dependency through self-service onboarding, leverages alternative data sources (SIM tenure, airtime patterns, Mobile Money behavior), and implements progressive enforcement mechanisms from soft warnings to device lockdown to regulatory SIM/IMEI blocking ensuring unparalleled loan recovery rates while maintaining compliance with Uganda's financial regulations.

The Problem Statement

Context: Uganda's low-to-middle income earners (boda riders, market vendors, casual laborers) earn UGX 200K-2M monthly but remain **underbanked**. They lack formal credit histories, operate in the informal economy, and rely heavily on Mobile Money for financial transactions.

The Pain Point: Traditional lenders reject these customers due to:

- **Lack of Credit History** (no formal banking relationships)
- **Income Volatility** (daily/weekly wage patterns)
- **No Physical Collateral** (cannot pledge assets)
- **High Default Risk** (no enforcement mechanisms)

Existing solutions require agent networks, lack deep regulatory integration, and cannot effectively enforce repayment without physical asset recovery.

The Consequence:

- **Financial Exclusion:** 70%+ of Ugandans locked out of formal credit
- **Predatory Lending:** Vulnerable populations exploited by loan sharks
- **Economic Stagnation:** Small businesses cannot access growth capital
- **Device Theft Risk:** Lack of collateral enforcement encourages fraud

The Requirement: A fully automated, regulatory-compliant platform that:

- Scores creditworthiness using **alternative data** (telecom behavior, Mobile Money)
- Uses **smartphones as digital collateral** with multi-layer enforcement
- Integrates with **NIRA** (identity), **UCC** (telecom), and **CRB** (credit bureaus)
- Provides **self-service onboarding** (zero agent dependency)
- Implements **progressive rehabilitation** for defaulters

The Solution: "Your Phone is Your Credit"

LOAN-NEXTGEN transforms **smartphone ownership** into a **creditworthy asset** by combining three breakthrough innovations:

1. Behavioral Telecom Scoring

The platform doesn't rely on traditional credit data. Instead, it analyzes:

- **SIM Tenure:** How long has the customer owned this number? (24+ months = trusted)
- **Airtime Consistency:** Regular top-ups indicate income stability
- **Mobile Money Patterns:** Transaction frequency, wallet balance, P2P transfers
- **Device Age:** Newer devices = higher collateral value

2. Deep Regulatory Integration

Direct API connections to Uganda's regulatory infrastructure:

- **NIRA API:** Biometric identity verification (NIN validation)
- **UCC Portal:** SIM blocking authority, IMEI validation, telecom data access
- **CRB:** Pre-checks, default reporting, dispute resolution

3. Unbreakable Device Control

Multi-layer security stack:

- **DeviceOwner Mode:** System-level app persistence (survives factory reset) **??**
- **Accessibility Services:** Monitor payment-related activities
- **Boot Persistence:** Auto-launch on device restart
- **Offline Tokens:** Lock enforcement works without the internet.

The Scoring Formula

LOAN-NEXTGEN uses a four-component behavioral scoring model that normalizes to a total score of 1.0.

Total Score Calculation

```
Total Score = (Identity × 0.X) + (Device × 0.Y) + (Telecom × 0.Z) + (Financial × 0.J)
```

In the production environment, the scoring engine will be fully **user-configurable**. The platform will provide an interface for users to **dynamically adjust scoring parameters** to align with their specific internal policies.

Component Breakdown

1. Identity Verification (X%)

Uses NIRA and CRB data to validate customer authenticity and credit history.

```
identity_score = (
    age_score * 0.40 +
    residence_score * 0.30 +
    crb_history_score * 0.30
) * 0.X
```

Data Sources:

- **NIRA API: NIN validation, DOB extraction, registered address**
- **Application: Self-reported residence duration**

Feature Example:

```
{
  "nin": "CM12345678BCDF",
  "dob": "1992-03-15",
  "registered_district": "Kampala",
  "registered_parish": "Nakawa",
  "residence_stability_months": 24,
}
```

2. Device Stability (Y%)

Assesses the value and history of the smartphone being used as collateral.

```
device_score = (
    device_age_score * 0.35 +
    imei_history_score * 0.35 +
  ) * 0.Y
```

Data Sources:

- UCC IMEI Registry: Device first activation date, blacklist status
- Device Info (Android): Manufacturer, model, build date
- Market Pricing API: Current device resale value ??

Feature Example:

```
{

  "imei": "352033101234567",

  "manufacturer": "Samsung",

  "model": "Galaxy A14",

  "previous_loan_count": 0,

  "ucc_blacklist": false

}
```

3. Telecom Behavior (Z%)

This component—analyzes SIM and Mobile Money patterns.

```
telecom_score = (

    sim_tenure_score * 0.25 +

    network_reputation_score * 0.20

) * 0.Z
```

<u>Data Sources:</u>

- UCC Telecom Data: SIM registration date, monthly airtime recharge patterns (6 months)
- MTN MoMo API: Transaction history, wallet balance, P2P patterns
- LMS History: Previous loan repayment behavior on this number

<u>Feature Example:</u>

```
{

  "msisdn": "+256782345678",

  "sim_registration_date": "2021-05-20",
```

```
  "sim_tenure_months": 57

}
```

4. Financial Behavior (J%)

Evaluates repayment history and income stability.

```
financial_score = (

    repayment_history_score * 0.50 +

    airtime_consistency_score * 0.25 +

    wallet_activity_score * 0.30 +

    income_stability_score * 0.30 +

    occupation_risk_score * 0.20

) * 0.J
```

Data Sources:

- LMS: Historical loan performance (if repeat customer)
- CRB API: Previous defaults, active loans, dispute flags
- Application: Self-reported income, occupation
- MoMo: Income pattern validation (inbound transfers)

Loan Decision Thresholds

Score Range	Loan Amount (UGX)	Repayment Frequency	Term Length	Interest Rate
0.8 - 1.0	500K - 2M	Monthly	15-30 days	10%
0.5 - 0.8	100K - 500K	Weekly	7-21 days	15%
0.3 - 0.5	20K - 100K	Daily	3-7 days	20%
< 0.3	Application Denied	-	-	-

Note: First-time borrowers start at lower limits regardless of score. Limits increase with successful repayment history.

N.B: To ensure alignment with evolving risk appetites, the production environment will feature **user-defined decisioning thresholds**. This allows administrators to **calibrate approval and rejection criteria** directly through the platform, ensuring every loan decision reflects current organizational policy.

Security & Compliance

Regulatory Compliance Framework

Regulation	Implementation
Uganda Data Protection Act 2019	Explicit consent capture, AES-256 encryption at rest/transit, Right to deletion APIs
UCC Guidelines	IMEI validation, SIM blocking authority, Telecom data access with consent
CRB Act 2016	Mandatory pre-checks, 90-day default reporting, Dispute resolution workflow

Multi-Layer Android Security

1. DeviceOwner Mode

- System-Level Permissions: Cannot be uninstalled by user
- Persistent Configuration: Kiosk settings enforced at boot

2. Accessibility Services

- Payment Activity Monitoring: Detects Mobile Money transactions
- App Usage Tracking: Identifies attempts to bypass locks
- Gesture Blocking: Prevents status bar pull-down when locked

3. Offline Token Caching

- JWT Storage: 7-day validity for lock enforcement
- Local State Machine: Works without internet connectivity
- Periodic Sync: Updates server when connection restored

Threat Mitigation Matrix

Threat	Likelihood	Impact	Mitigation
Device reset to bypass lock	High	High	DeviceOwner + FRP + IMEI tracking
SIM swap to avoid blocks	Medium	High	IMEI primary identifier + UCC cross-check
Root access to disable app	Medium	High	Root detection + immediate lock + backend alert
Multiple devices per customer	Medium	Medium	IMEI+MSISDN pairing + CRB cross-reference
Fake identity documents	Low	High	3D Mapping & selfie match

Collusion with agents	Low	Medium	Self-service only (no agents)
Network unavailability	High	Low	Periodic sync
UCC block delays	Medium	Medium	Automated tracking + escalation
Customer harassment	Low	High	Clear terms + progressive locks + compliance audit

---

Getting Started

Prerequisites

- Development Environment:
  - Android Studio (Kotlin development)
  - Python 3.11+ (for FastAPI backend)
  - Next.js 20+ (Frontend)
  - Docker & Docker Compose
- External Services:
  - NIRA API access credentials
  - UCC Portal API key
  - CRB integration license
  - MTN MoMo API sandbox/production keys
- Infrastructure:
  - PostgreSQL 15+ (Database)
  - Redis 7+ (Caching)
  - RabbitMQ 3.12+ (Message Queuing)

Quick Start (Development Mode)

Clone the Repository
```
git clone https://github.com/org/loan-nextgen.git

cd loan-nextgen
```

1.

Set Environment Variables
```
cp .env
```

```
# Edit .env with your API keys
```

2.

Start Infrastructure

```
docker-compose up -d postgres redis rabbitmq
```

3.

Run Database Migrations

```
cd backend

atlas migrate diff local env
```

4.

Start Backend Services

```
# Terminal 1: API Server

cd backend

uvicorn app.main:app --reload --port 8000



# Terminal 2: Background Workers

cd backend

celery -A app.tasks.worker worker --loglevel=info
```

5.

Start kotlin App

```
cd mobile
```

kotlin `pub get`

kotlin `run`

6. Access Points
   - Mobile App: Connected Android device/emulator
   - API Docs: `http://localhost:8000/docs`
   - Admin Dashboard: `http://localhost:3000`
   - Flower (Celery Monitor): `http://localhost:5555`

FUNCTIONAL REQUIREMENTS

LOAN-NEXTGEN requires a comprehensive set of functional requirements to deliver automated micro-lending with regulatory compliance and device-based enforcement for Uganda's underbanked users.

User Registration Requirements

New users must complete self-service onboarding without agent intervention. The system shall collect MSISDN, NIN, DOB, selfie, and self-reported residence details via the Kotlin app.

Parallel verification occurs against NIRA for biometric identity confirmation, UCC for IMEI and SIM tenure validation, and CRB for credit history including defaults and active loans.

Users digitally sign consent for data access and enforcement mechanisms before proceeding. Registration succeeds only if identity passes, low scores will trigger denial with improvement tips like maintaining SIM tenure over 24 months among others.

Credit Scoring Requirements

The system calculates a normalized total score from four dynamically weighted components namely; Identity (X%), Device (Y%), Telecom (Z%), and Financial (J%).

Identity scoring uses age bands (18-25: 0.6, 26-35: 0.9, 36-55: 1.0, 55+: 0.8), residence stability, and CRB defaults.

Device scoring assesses age (<6 months: 1.0), IMEI history, and resale value (>UGX 800K: 1.0).

Telecom scoring prioritizes SIM tenure (24+ months: 1.0), airtime recharge consistency (CV <0.3 preferred), and MTN MoMo transaction volume.

Financial scoring evaluates repayment history, wallet activity (>10 transactions/month: 1.0), and occupation risk. Scores map to tiered loan offers: 0.8+ yields UGX 500K-2M at 10% interest; below 0.3 denies applications.

Loan Application and Disbursement

Approved users view personalized terms including amount, frequency (daily/weekly/monthly), term (3-30 days), and interest.

Loan acceptance triggers MTN MoMo disbursement with transaction reference confirmation.

The system generates repayment schedules and sends initial 24 hour pre-due payment reminder SMS alerts.

First-time borrowers receive conservative limits that scale with on-time repayments (+x% boost per cycle).

All disbursements log audit trails for UDPA compliance.

Repayment Monitoring Requirements

The Next Gen system tracks and stores information about the loan status from Active to Closed.

Pre-due alerts send informative reminders, grace periods allow one day overdue notifications.

The system detects payments via Accessibility Services monitoring MoMo transactions.

Partial payments extend kiosk mode until full settlement plus fees while background Celery workers poll Redis caches hourly for overdue triggers.

Enforcement and Lock Mechanisms

Overdue loans escalate progressively:

Day 1: triggers Kiosk Mode, restricting the device to payment-only access via Kotlin DeviceOwner permissions that persist through reboots and resets. Boot receivers auto-launch the app, and offline JWT tokens enforce locks without internet.

Day 30: submits UCC SIM block requests, halting calls and data.

Day 90: activates IMEI blacklisting and CRB reporting. Reversals occur instantly on late payments with unblock coordination. Root detection or bypass attempts trigger immediate locks and backend alerts.

Regulatory Integration Requirements

NIRA API handles NIN/DOB validation and address extraction.

UCC provides SIM registration dates, IMEI history, airtime patterns, and block authority.

CRB supplies a defaults-count, active loans, and scores for pre-checks; 90-day defaults auto-report.

MTN MoMo enables disbursement, balance queries, and transaction history for scoring. All integrations require explicit consent with AES-256 encryption and deletion APIs as per the Uganda Data Protection Act.

Admin Dashboard Requirements

Agents access React-based portals for loan oversight, customer reports, and score analytics. Features include loan lists filtered by status, repayment charts, and CRB dispute workflows. Real-time metrics via Prometheus/Grafana monitor disbursement volumes and recovery rates. Audit logs capture all actions for compliance reviews.

Data Management Requirements

PostgreSQL stores loans, users, and transactional scores.

Redis handles sessions, rate limits, and offline tokens.

RabbitMQ queues async tasks like SMS and UCC submissions.

Feature stores retain airtime recharges, MoMo patterns, and historical scores for ML retraining. Pytest suites validate scoring logic; migrations use Atlas.

Security and Compliance Requirements

JWT authentication secures API Gateway with WAF protection. Bcrypt hashes credentials; Sentry tracks errors.

Consent trails log all data access.

Threat mitigations include FRP for resets, IMEI-MSISDN pairing against swaps, and 3D selfie matching for fraud, self-service eliminates agent collusion risks.

Error Handling and Edge Cases

Network outages sync states periodically on reconnect.

UCC delays trigger escalations.

Rehabilitation requires three on-time micro-payments post-default.

Denied users receive score breakdowns and tips.

All flows produce receipts and support disputes via CRB workflows.

BUSINESS REQUIREMENTS

LOAN-NEXTGEN targets Uganda's underbanked low-to-middle income earners (UGX 200K-2M monthly) by providing automated micro-loans using smartphones as collateral and telecom behavioral data for scoring.

Business Objectives

Achieve 70%+ financial inclusion for informal workers like boda riders and vendors by eliminating credit history barriers.

Deliver high loan recovery through progressive enforcement including device locks and regulatory blocks.

Scale to 1M+ users by Q4 2028 via self-service onboarding and MTN MoMo integration.

Comply fully with UMRA Tier 4 licensing, BoU guidelines, and UDPA 2019 to avoid sanctions.

Target Market

Primary: Uganda's 70% underbanked population lacking formal credit, including casual laborers, market vendors, and boda operators aged 18-55 in urban/rural areas.

Secondary: Repeat borrowers building scores via on-time repayments. Market size supports high growth in digital lending amid 50%+ mobile money penetration.

Key Value Propositions

Offer instant loans without agents using SIM tenure, airtime patterns, and device IMEI as proxies for creditworthiness.

Provide tiered limits (UGX 20K-2M) with dynamic rates (10-20%) based on scores 0.3+.

Ensure unbreakable recovery via kiosk mode, SIM/IMEI blocks, and CRB reporting. Include financial education and rehab paths for defaulters.

Revenue Model

Earn from interest (10-20% flat) on disbursements, plus late fees on overdue loans. Project 15% average yield on UGX 500K average loans at 80% utilization.

No deposit-taking; fund via institutional capital targeting UGX 50M minimum per UMRA rules. Scale revenue through repeat loans (score boosts) and Phase 4 expansions like B2B/SACCO integrations.

Regulatory Compliance Requirements

Secure UMRA Tier 4 money lender license with UGX 50M capital proof, police clearances, and physical address.

Adhere to Digital Lending Guidelines: explicit consent, monthly UMRA reporting, consumer protection (transparent terms, no harassment), AML via NIRA/CRB, and data confidentiality.

Integrate mandatory pre-checks with CRB, UCC blocks only post-30 days, and UDPA deletion rights.

Obtain BoU permission for MoMo payments monitoring.

Success Metrics

Metric	Target (Q2 2026)	Measurement
Active Users	100K	Monthly active loans
Recovery Rate	95%	Repaid/Disbursed ratio
PAR 30+	<5%	Loans overdue 30 days
CAC	<UGX 5K	Acquisition cost per user
NPS	>70	User satisfaction score
AUM	UGX 50B	Assets under management

Operational Requirements

Self-service via Android 9+ Kotlin app; no agents for onboarding/disbursement.

Backend FastAPI handles scoring/ML inference.

Integrate NIRA/UCC/CRB/MoMo APIs with 99.9% uptime.

Monthly UMRA reports on loans, defaults, and complaints. Physical office for compliance audits.

Risks and Mitigations

Risk	Likelihood	Mitigation
Regulatory sanctions	High	UMRA license + monthly reporting
Low recovery	Medium	Escalating locks + UCC integration
Fraud (fake NIN/SIM swap)	Medium	Biometrics + IMEI pairing
Funding shortages	High	Secure UGX 50M capital upfront
Market competition (Zenka/Emata)	Medium	Superior enforcement/recoveryheconsulting+1

Phased Rollout

Phase 1 (Current): MVP with MTN-only, kiosk enforcement.

Phase 2 (Q2): Multi-network, full UCC automation.

Phase 3 (Q3): AI fraud detection.

Phase 4 (Q4): B2B/insurance bundles. Each phase requires UMRA approvals for expansions.

ARCHITECTURAL DOCUMENTATION

LOAN-NEXTGEN employs a microservices architecture centered on FastAPI backend, Kotlin mobile frontend, and PostgreSQL persistence to deliver real-time lending decisions and device enforcement for Uganda's microfinance market.

System Overview

The platform decomposes into layered components: client touchpoints (Kotlin app, React dashboard), core platform (API gateway, scoring engine, enforcement system), data layer (PostgreSQL, Redis, RabbitMQ), external integrations (NIRA, UCC, CRB, MTN MoMo), and security services (WAF, audit logging).

All traffic routes through JWT-authenticated API Gateway with rate limiting.

Async processing via Celery workers handles overdue monitoring and UCC block submissions.

The architecture supports 99.9% uptime through Docker containerization and Prometheus monitoring.

Core Components

Client Layer

Kotlin-based Android app (API 28+) handles self-registration, biometric capture, kiosk mode enforcement via Kotlin DeviceOwner permissions, and accessibility services for payment monitoring.

React TypeScript dashboard provides agent views for loan oversight, score analytics, and CRB dispute workflows.

Both clients communicate via HTTPS/JSON over API Gateway.

API Gateway

FastAPI serves as a unified entrypoint with OpenAPI documentation at /docs. Implements JWT authentication, bcrypt password hashing, and request validation via Pydantic schemas.

Routes requests to microservices: Loan Orchestrator, Scoring Engine, Payment Monitor.

WAF filters SQL injection and XSS; Redis enforces rate limits (100 req/min per MSISDN).

Behavioral Scoring Engine

Loan orchestrator coordinates four weighted sub-models: Identity (NIRA/CRB), Device (UCC IMEI), Telecom (airtime/MoMo patterns), Financial (repayment history). Gradient Boosting ML inference runs feature engineering on normalized inputs (SIM tenure, CV of recharges, wallet velocity). Scores threshold at 0.3 for approval; outputs tiered limits (UGX 20K-2M).

Enforcement System

Real-time state machine tracks repayment via RabbitMQ events. Triggers escalate:

Day 1 activates kiosk controller (boot-persistent, offline JWT enforcement);

Day 30 queues UCC SIM block;

Day 90 submits IMEI blacklist and CRB report. Kotlin services persist through factory resets using FRP and root detection.

Data Flow Architecture

```
Customer App → API Gateway → Loan Orchestrator → Parallel Services:

├── Scoring: NIRA/UCC/CRB  → Score

├── Disbursement: MTN MoMo → Wallet Credit

└── Monitoring: Redis Cache → Celery Worker → RabbitMQ Events
```

PostgreSQL schemas store Loans (status, schedule), Users (NIN, MSISDN, IMEI), Scores (component breakdowns).

Redis holds sessions (JWT TTL 30min), offline lock tokens. RabbitMQ queues SMS notifications, UCC submissions.

Atlas migrations ensure schema evolution.

External Integrations

Service	Purpose	Protocol	Error Handling
NIRA	NIN/DOB/address validation	REST API	Retry 3x, fallback to manual

UCC	IMEI/SIM data, blocks	Portal API	Async queue, escalation alerts
CRB	Defaults count, reporting	SOAP API	90-day auto-submit
MTN MoMo	Disbursement, txn history	REST + Webhook	Idempotency keys

All calls include consent audit trails per UDPA; AES-256 encrypts PII at rest/transit.

Deployment Architecture

Docker Compose manages a multi-container architecture consisting of a **Uvicorn/Celery backend**, a robust **Nginx frontend**, and a scalable infrastructure layer featuring **PostgreSQL, Redis, and RabbitMQ**.

Optimization for high availability achieved with the help of Kubernetes orchestration, employing **horizontal scaling** of API and Worker pods to handle fluctuating workloads seamlessly.

Sentry captures exceptions; Prometheus/Grafana dashboards track latency (p95 <200ms), recovery rates, PAR30. CI/CD via GitHub Actions runs pytest (90% coverage), security scans.

Security Architecture

- **Authentication**: JWT with RS256 signing, refresh tokens in HttpOnly cookies.
- **Authorization**: Role-based (user/agent/admin) via dependency injection.
- **Device Lock**: System-level persistence survives uninstall/reset; accessibility monitors MoMo intents.
- **Compliance**: WAF blocks threats; immutable audit logs in PostgreSQL; deletion APIs for UDPA right-to-forget.
- **Threat Model**: FRP blocks resets; IMEI-MSISDN binding defeats swaps; 3D liveness detects selfie fraud.

Scalability Patterns

Event-driven design decouples services via RabbitMQ.

Stateless APIs scale horizontally.

Redis clustering handles 10K concurrent sessions.

ML inference caches frequent scores. Database partitioning by MSISDN sharding supports 1M+ users by Q4 2028.

Non-Functional Requirements

Category	Requirement
Availability	99.9% (72min/year downtime)
Latency	Decision <2s p95; disbursal <5s
Throughput	1000 apps/min peak
Data Retention	Loans: 7 years; Scores: 2 years
Backup	Daily pg_dump, S3 geo-redundant

This architecture enables Phase 2 multi-network expansion and Phase 3 LSTM models without core rewrites.

TEST PLAN

LOAN-NEXTGEN requires comprehensive testing across mobile, backend, and integrations to ensure 95%+ recovery rates and full regulatory compliance before production deployment.

Test Objectives

Validate end-to-end loan lifecycle from registration to enforcement under real Uganda network conditions.

Achieve 90% automated test coverage for scoring logic, API endpoints, and device lock persistence.

Confirm zero PII leaks and 100% UMRA compliance through audit log verification.

Test on Android 9-14 across Samsung, Tecno, Infinix (80% Uganda market share) with MTN 3G/4G simulation.

Test Scope

In-Scope	Out-of-Scope
Self-registration + NIRA/UCC/CRB verification	Agent desktop workflows
4-component behavioral scoring engine	Marketing website
Kiosk mode enforcement (boot/factory reset)	iOS development
MTN MoMo disbursement + payment monitoring	Physical collateral recovery
Progressive lock escalation (Day1-Day90)	B2B/SACCO integrations

Test Environment Requirements

- **Devices**: 15 physical Androids (A9-A14, 2-6GB RAM) + Genymotion cloud farm
- **Backend**: Docker Compose (FastAPI + PostgreSQL + Redis + RabbitMQ)
- **Network**: Charles Proxy (3G throttling, 100ms latency, 20% packet loss)
- **Mock APIs**: WireMock servers for NIRA/UCC/CRB/MoMo
- **Monitoring**: Sentry + Prometheus dashboards

Test Types and Coverage

1. Unit Tests (Pytest/JUnit)

```
Backend: 90% coverage
```

- scoring.py: All 4 components + edge cases (age bands, SIM tenure <6mo)

- enforcement.py: State machine transitions + offline JWT validation

- models.py: SQLAlchemy constraints + Pydantic validation

Mobile: 85% coverage

- device_owner_service.kt: Boot receiver + FRP persistence

- accessibility_monitor.kt: MoMo intent detection

- kiosk_controller.kt: Gesture blocking + status bar prevention

2. API Integration Tests

FastAPI endpoints (Swagger /docs):

- POST /auth/register: Parallel NIRA+UCC+CRB (200/400/429)

- POST /loans/apply: Score thresholds (0.3 deny, 0.8+ approve)

- POST /payments/monitor: Webhook idempotency + partial payments

- Rate limiting: 100 req/min per MSISDN

3. End-to-End Mobile Flows

Critical User Journeys (kotlin + Appium):

1. Registration → Verification → Loan Offer → Disburse (T<30s)

2. Day1 Overdue → Kiosk Activate → Partial Pay → Still Locked

3. Day30 → SIM Block Request → Late Payment → Unblock

```
4. Factory Reset → App Persists → Lock Re-enforced

5. Airplane Mode → Offline Lock → Network Restore → Sync
```

4. Performance Tests

```
Load: 1000 concurrent registrations (Artillery)

Stress: 10K pending kiosks (Locust)

Soak: 72hr enforcement monitoring (k6)

Targets: p95 <2s scoring, 0% lock failures
```

5. Security Tests

```
OWASP MASVS L1 (Mobile) + API:

- DeviceOwner bypass (root, adb, shizuku)

- NIN selfie replay attacks (3D liveness)

- MoMo transaction interception (certificate pinning)

- Offline JWT forgery (key extraction)

- UDPA deletion endpoint (complete PII purge)
```

Test Case Prioritization

Priority	Test Suite	# Cases	Automation
S0/CRITICAL	Registration + Scoring	45	100%
S1/HIGH	Kiosk Enforcement	32	95%
S2/MEDIUM	Payment Monitoring	28	80%
S3/LOW	Admin Dashboard	15	50%

Device Matrix

Brand	Model	Android	RAM	Network	Purpose
Samsung	A14	13	4GB	MTN 4G	Primary
Tecno	Spark 10	12	4GB	MTN 3G	Budget
Infinix	Hot 30	13	8GB	Airtel 4G	Premium
Xiaomi	Redmi 9	10	3GB	MTN 3G	Legacy

Test Execution Schedule

```
Sprint 0 (Week 1): Environment setup + unit tests

Sprint 1 (Week 2): API + registration E2E

Sprint 2 (Week 3): Kiosk enforcement + security

Sprint 3 (Week 4): Performance + cross-device

Week 5: Regression + UAT + bug triage

Week 6: Production smoke tests
```

Entry/Exit Criteria

Entry: 90% unit coverage, mock APIs operational, 15 devices ready
Exit:

- 100% S0 tests pass
- 95% overall pass rate
- Zero P1/P2 bugs
- Recovery simulation: 98% success
- Load tests meet SLA

Defect Management

Severity	Criteria	SLA
P0 Block	Registration fails, kiosk doesn't lock	Fix same day
P1 Critical	Wrong scores (>0.1 error), MoMo fails	Fix within 24h
P2 High	UI crashes, slow scoring (>5s)	Fix current sprint
P3 Low	Cosmetic, edge cases	Fix next sprint

Regression Strategy

Daily CI pipeline (GitHub Actions):

```
pytest backend/ --cov=90%

kotlin test mobile/

appium e2e/ --devices=3

playwright dashboard/
```

Risk-Based Testing Focus

- **Kiosk Persistence** (Factory reset survival)
- **Scoring Accuracy** (SIM tenure edge cases)
- **Offline Enforcement** (7-day no network)
- **Regulatory APIs** (NIRA downtime handling)
- **Root Detection** (Magisk + bypass tools)

This plan ensures production readiness for Uganda's challenging mobile ecosystem while meeting UMRA compliance requirements.

CHALLENGES

LOAN-NEXTGEN faces significant technical, regulatory, and operational challenges in Uganda's volatile micro-lending environment that threaten 95% recovery targets and UMRA compliance.

Regulatory Compliance Challenges

Fragmented oversight (UMRA (Uganda Microfinance Regulatory Authority), BoU, NITA, UCC) causes approval delays on average 6 months for NIRA/UCC API access.

Digital Lending Guidelines mandate explicit consent capture, transparent APR disclosure, and prohibition of harassment, risking license revocation for any kiosk mode complaint.

CRB 90-day reporting conflicts with rehabilitation paths, creating scoring disincentives.

Technical Enforcement Limitations

DeviceOwner mode fails on 15%+ rooted devices despite Magisk detection; FRP bypass via Google account recovery remains possible.

UCC SIM/IMEI blocking suffers 48-72 hour processing delays, creating enforcement gaps during Day 30-90 escalation.

Offline JWT tokens vulnerable to physical extraction on low-end Tecno/Infinix devices lacking hardware security.

Data Integration Barriers

NIRA API uptime averages 85% with frequent 503s during peak hours; no fallback exists for identity verification.

Fragmented tele-communication data ecosystems lack standardized airtime utilization APIs, necessitating bespoke integration for each carrier.

Manual portal scraping violates automation rules.

The shift toward **non-resettable identifier restrictions** in modern Android versions creates a significant 'enforcement gap' because external apps can no longer extract the IMEI, we lose the primary anchor for **identity-based locking**; without this hardware handshake, enforcing a lock consequence becomes reliant on software-level IDs that can be bypassed or reset, limiting our long-term control over the device.

Market and Fraud Risks

SIM swapping bypasses standard **MSISDN authentication anchors**. This risk is compounded by a **24-hour synchronization window** for UCC registry changes, creating a critical latency period that fraudsters can exploit.

Boda riders share devices across family members, inflating scores via airtime pooling which makes it ineffective as a method to determine credit worthiness.

Rural 3G coverage drops to 40% coverage that could potentially break kiosk sync and enforcement.

Competition from Zenka/Emata forces aggressive scoring thresholds, risking PAR30 >10%.

Scoring Model Weaknesses

SIM tenure >24 months excludes 60% new market entrants, contradicting inclusion goals. Airtime CV <0.3 favors salaried over daily wage earners (true target market).

No income volatility adjustment for seasonal workers (Xmas, planting seasons).

Operational Scaling Constraints

Celery workers handling 10K+ daily overdue checks overwhelm a single RabbitMQ instance; queue lag reaches 2+ hours.

PostgreSQL write contention on loan status updates causes 500s during repayment spikes.

No multi-region failover for Kampala data center dependency.

Manual UMRA report generation takes 3 days/month, delaying compliance.

User Experience Trade-offs

Kiosk mode renders devices unusable for non-payments, triggering complaints despite legal consent.

Current **initial disbursement caps** of UGX 20K fail to meet the **minimum daily working capital requirements** for boda-boda operators, which averagely is UGX 50K.

3D liveness detection shows significant environmental sensitivity in rural settings; potential unsatisfactory lighting conditions are responsible for a high registration dropout rate due to biometric verification failure.

To maximize **onboarding conversion**, we must address the **localization gap**; currently, a big percentage of our core audience is underserved by the **English-centric user flow**."

Risk Priority Matrix

Risk	Impact	Likelihood	Mitigation Status
UMRA license revocation	Critical	High	Legal review complete
UCC API downtime	High	High	Mock servers ready
Root bypass success	Critical	Medium	Kernel-level hooks R&D
SIM swap fraud	High	High	Biometric + geolocation
Rural network failure	Medium	High	SMS + USSD fallback
Scoring exclusion	Medium	Medium	ARIMA seasonality model

Phase-Specific Mitigations

Phase 1 (Current): Prioritize mock APIs + legal compliance over live integrations. Cap daily disbursements at UGX 2M.
Phase 2 (Q2): Kubernetes auto-scaling + Redis Cluster for 100K users.
Phase 3 (Q3): LSTM transaction models + on-device ML for offline scoring.
Phase 4 (Q4): USSD channel for 2G-only rural access.

These challenges demand parallel technical hardening with regulatory navigation, targeting 80% mitigation before production launch.